Lesson 7

Implementing Authentication Controls

CompTIA®

Identity and Access Management

- Subjects
  - Users or software that request access
- Objects
  - Resources such as networks, servers, and data
- Identification
  - Associating a valid subject with a computer/network account
- Authentication
  - Challenge to the subject to supply a credential to operate the account
- Authorization
  - Rights, permissions, or privileges assigned to the account
- Accounting
  - Auditing use of the account

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Authentication Factors

- Something you know
  - Knowledge factor
  - Password
  - Personal identification number (PIN)
  - Swipe pattern
  - Challenge questions/password reset
- Something you have
  - Ownership factor
  - Hardware tokens and fobs
- Something you are/do
  - Biometric factor

Screenshot used with permission from Microsoft.

Authentication Design

- Meet requirements for confidentiality, integrity, and availability
- Confidentiality
  - Keep credentials secure
- Integrity
  - Threat actors cannot bypass or subvert the authentication mechanism
- Availability
  - The mechanism does not cause undue delay or support issues

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Multifactor Authentication

- Strong authentication requires two (or three) types
  - Knowledge factor only is weak in terms of confidentiality
- Multifactor authentication (MFA)
- Two-factor authentication (2FA)
  - Something you KNOW and something you HAVE
  - Something you KNOW and something you ARE
  - NOT something you KNOW and something else you KNOW

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Authentication Attributes

- Somewhere you are
  - Geolocation via location services
  - IP location (logical versus geolocation)
  - Switch port, virtual LAN (VLAN), or wireless network name
- Something you can do
  - Performing an action in a way that can be captured as a unique pattern
- Something you exhibit
  - A behavior or personality trait that can be captured as a unique pattern
- Someone you know
  - Web of trust

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Topic 7B

Implement Knowledge-based Authentication

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

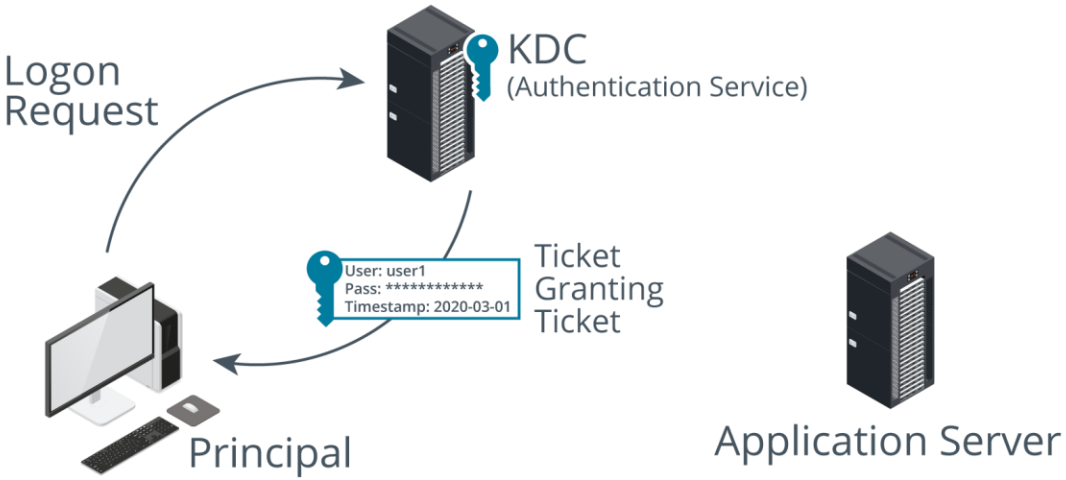
Local , Network, and Remote Authentication

- Authentication providers
  - Passwords versus password hashes
- Windows authentication
  - Local sign-in
  - Network sign-in (Kerberos and NTLM)
  - Remote sign-in
- Linux authentication
  - /etc/passwd and /etc/shadow
  - Pluggable authentication modules (PAMs)
- Single sign-on (SSO)

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

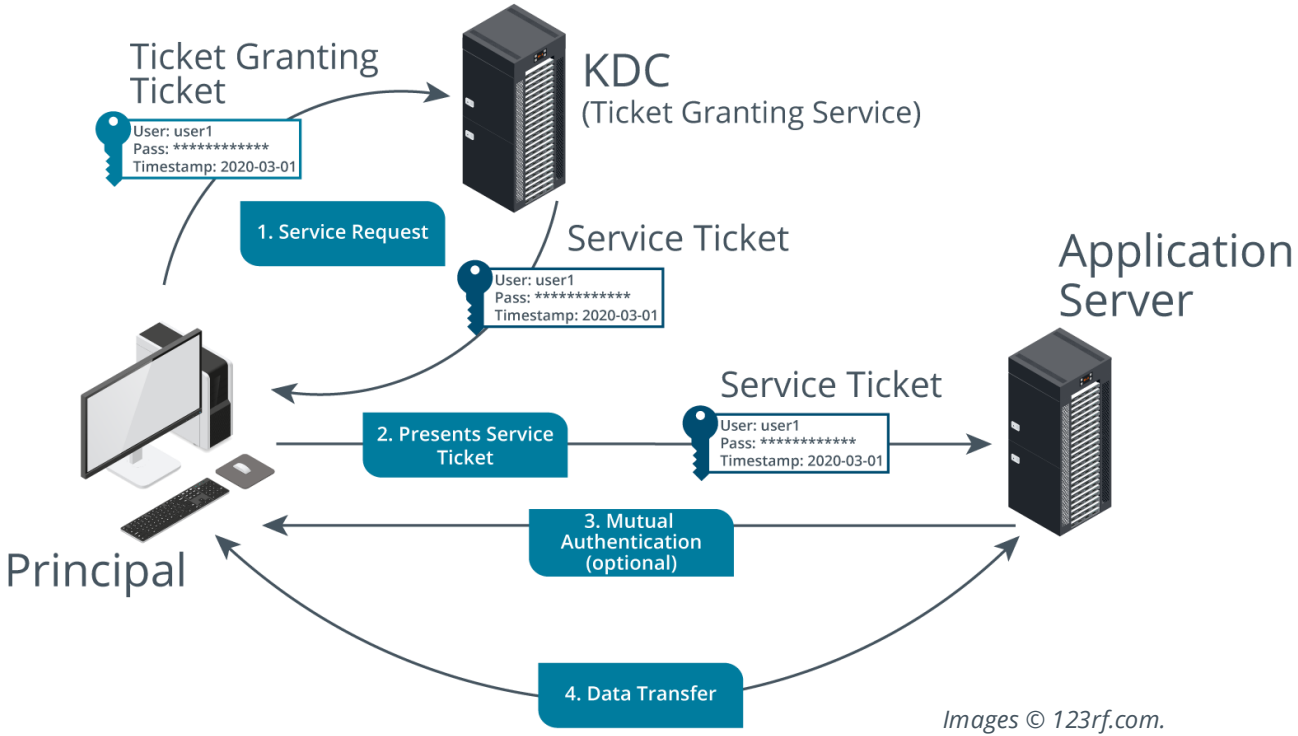
Kerberos Authentication

- Single sign-on authentication and authorization provider
- Clients
- Application servers
- Key Distribution Center (KDC)
  - Authentication Service – Ticket Granting Ticket
  - Ticket Granting Service – Service Ticket



Images © 123rf.com.

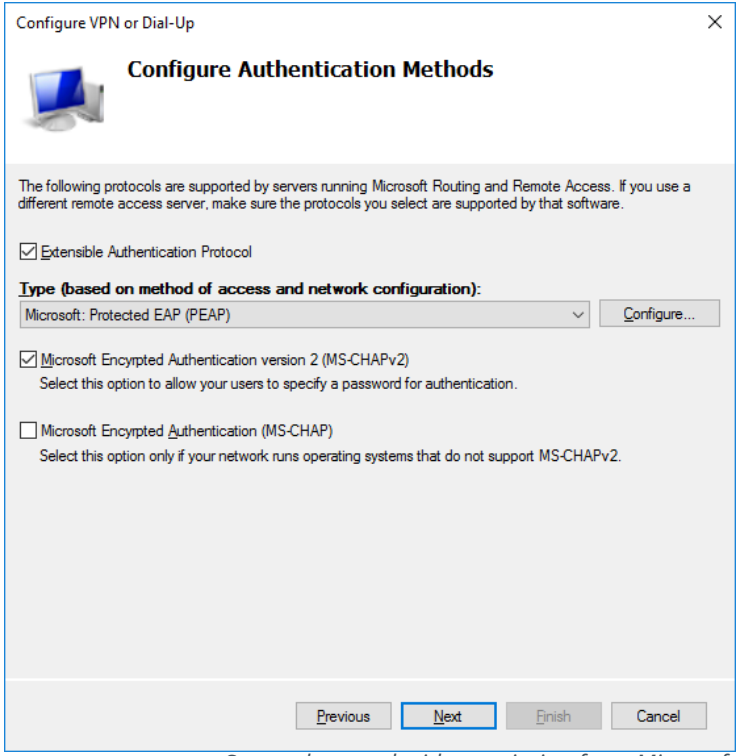
Kerberos Authorization



Images © 123rf.com.

PAP, CHAP, and MS-CHAP Authentication

- Password authentication designed to work with remote access protocols (Point-to-Point Protocol)
- Password Authentication Protocol (PAP)
  - Completely unsecure
- Challenge Handshake Authentication Protocol (CHAP)
  - Challenge/Response similar to NTLM
  - Challenge is repeated during the session to prevent replay
  - Various implementations (Cisco, MS-CHAPv2)
  - Not secure enough to use without an encrypted tunnel



Screenshot used with permission from Microsoft.

Password Attacks

- Plaintext/unencrypted
  - Sniffing passwords from unsecure protocols
  - Locating passwords in documents/code repositories
- Online password attack
  - Adversary interacts with authentication service
  - Restrict logon rates
  - Shun suspect hosts
- Horizontal brute force/password spraying
- Offline attacks
  - Password database
  - Hash transmitted directly
  - Hash used as key to sign an HMAC

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Brute Force and Dictionary Attacks

- Exploit weak user password selection or weak cryptographic mechanisms
- Brute force attack
  - Generate every possible combination to match a hash
  - Large output space and sufficiently long input password increase time required
- Dictionary attack and rainbow tables
  - Use a dictionary to test common words or phrases first
  - Rainbow tables assist dictionary attacks against Windows password databases by precomputing hash chains
  - Using salt means hash chains cannot be pre-computed
- Hybrid attack
  - Dictionary and brute force
  - Fuzzing of dictionary terms (james1, james2, tom1, tom2,…)

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Password Crackers

```
[s]status [p]ause [b]ypass [c]heckpoint [q]uit => s

Session..........: hashcat
Status...........: Running
Hash.Type........: NetNTLMv2
Hash.Target......: ADMINISTRATOR::515support:2f8cbd19fd1bfac9:881c5503...000000
Time.Started.....: Mon Jan  6 11:25:16 2020 (1 min, 38 secs)
Time.Estimated...: Sat Jan 11 07:49:57 2020 (4 days, 20 hours)
Guess.Mask.......: ?1?1?1?1?1?1?1?1 [8]
Guess.Charset....: -1 pPaAsSwWoOrRdD0123456789$, -2 Undefined, -3 Undefined, -4
Undefined
Guess.Queue......: 1/1 (100.00%)
Speed.#1.........:   364.1 kH/s (11.09ms) @ Accel:128 Loops:32 Thr:1 Vec:8
Recovered........: 0/1 (0.00%) Digests, 0/1 (0.00%) Salts
Progress.........: 34233472/152587890625 (0.02%)
Rejected.........: 0/34233472 (0.00%)
Restore.Point....: 2176/9765625 (0.02%)
Restore.Sub.#1...: Salt:0 Amplifier:1824-1856 Iteration:0-32
Candidates.#1....: $87r8678 -> dSDoRS12
```

Screenshot hashcat (hashcat.net/hashcat.)

- Cain and L0phtcrack
- Hashcat
  - Hash type
  - Attack mode
    - Dictionary/word lists
    - Brute force
    - Masked

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Authentication Management

- Hardware and software solutions for storing and submitting multiple user passwords
- Password key
  - USB token
  - Possibly Bluetooth/NFC connectivity
- Password vaults
  - Software-based
- Federal Information Processing standard (FIPS 140-2)

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Topic 7C

Implement Authentication Technologies

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Smart Card Authentication

Image © 123RF.com.

- Kerberos-based smart card logon
- Card readers
- Card stores user's private key and certificate
- Use of card is protected by a PIN

Key Management Devices

- Provision keys with risk of insider threat reduced
- Smart cards and USB keys
- Trusted Platform Module (TPM)
  - Virtual smart cards
- Hardware Security Module (HSM)
  - Provision keys to devices across the network
  - Key archive and escrow
  - Reduced attack surface and tamper-evident
  - Cryptographically secure pseudorandom number generator (CSPRNG)
  - Plug-in card and network rack form factors

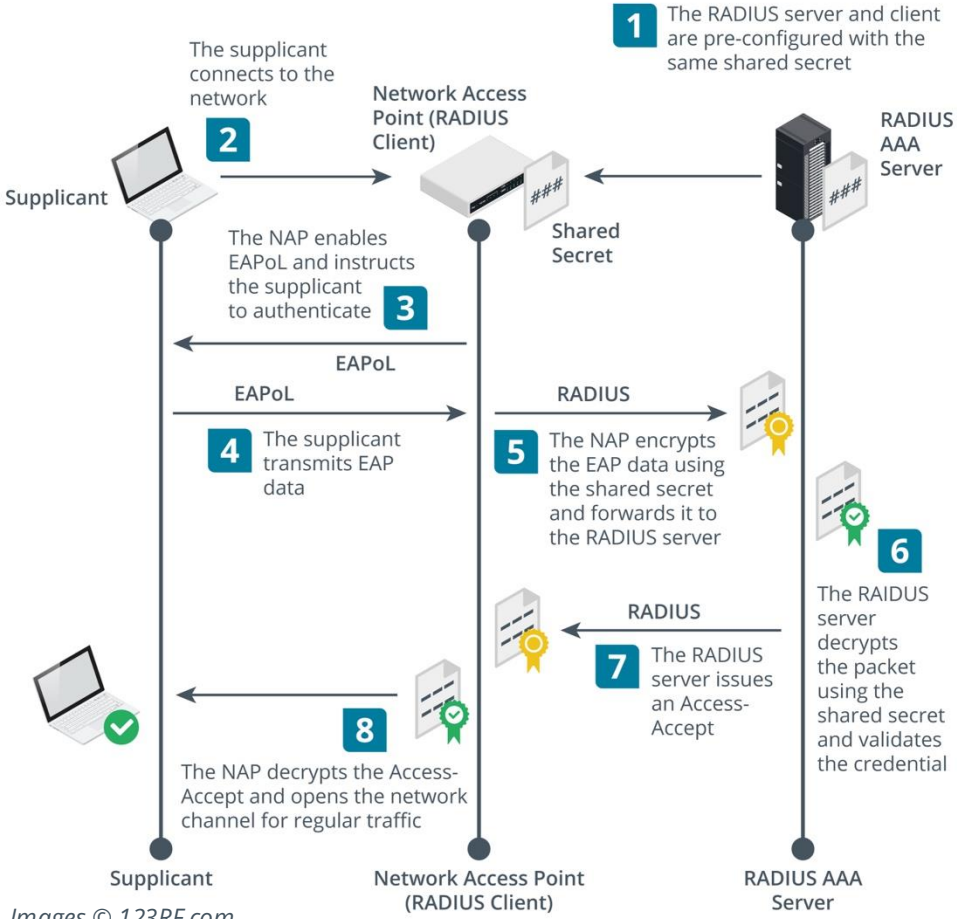
Images © 123RF.com.

Extensible Authentication Protocol/IEEE 802.1X

- Authenticate user at network access devices
  - Wireless networks
  - Port authentication for switched networks
  - Remote access over a virtual private network
- Extensible Authentication Protocol (EAP)
  - Supports multiple authentication implementations
  - Certificates and smart cards
- IEEE 802.1X Port-based Network Access Control
  - Supplicant
  - Network access server (NAS)
  - AAA server

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Remote Authentication Dial-in User Service



Images © 123RF.com.

Terminal Access Controller Access-Control System

- TACACS+
- Centralizing administrative logins for network appliances
- Reliable TCP transport (over port 49)
- Data encryption
- Discrete authentication, authorization, and accounting functions

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

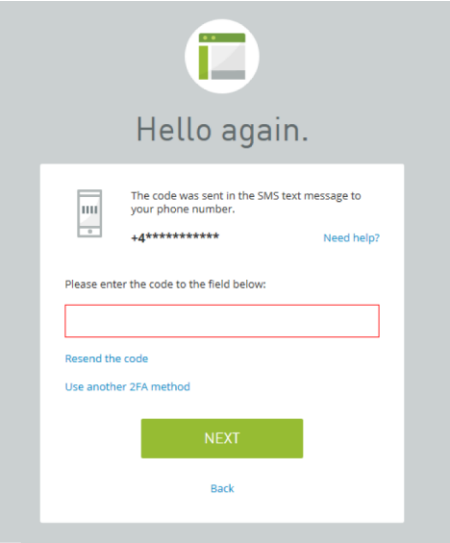
Token Keys and Static Codes

- One-time password (OTP)
  - Generated by some algorithm and used only once
  - RSA SecurID
- Static code
  - “Dumb” smart cards
- Fast Identity Online (FIDO) Universal Second Factor (U2F)

Image © 123RF.com.

Open Authentication (OATH)

- HMAC-based One-time Password Algorithm (HOTP)
- Time-based One-time Password Algorithm (TOTP)



2-Step Verification

- Transmit a code via an out-of-band channel
  - Short message service (SMS)
  - Phone call
  - Push notification
  - Email account
- Possibility of interception

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Topic 7D

Summarize Biometrics Authentication Concepts

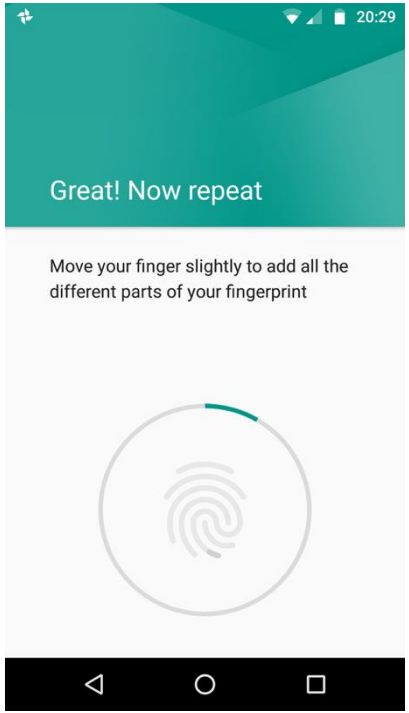
Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Biometric Authentication

- Enrollment
  - Sensor and feature extraction
- Efficacy rates and considerations
  - False Rejection Rate (FRR) or Type I error
  - False Acceptance Rate (FAR) or Type II error
  - Crossover Error Rate (CER)
  - Throughput (speed)
  - Failure to Enrol Rate (FER)
  - Cost/implementation
  - Privacy concerns
  - Accessibility concerns

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Fingerprint Recognition



Android is a trademark of Google LLC.

- Fingerprint sensors
  - Small capacitive cells
  - Easy to implement
  - Relatively simple enrollment
  - Quite vulnerable to spoofing
- Vein matching (vascular biometrics)
  - More complex scanner

Facial Recognition

- Facial recognition
  - Enrollment can be relatively slow
  - Privacy issues
  - Prone to relatively high false acceptance/rejection rates/spoofing
- Retinal scan
  - Pattern of blood vessels
  - Scanning relatively intrusive and complex
- Iris scan
  - Pattern of eye surface
  - Easier to scan
  - More vulnerable to spoofing

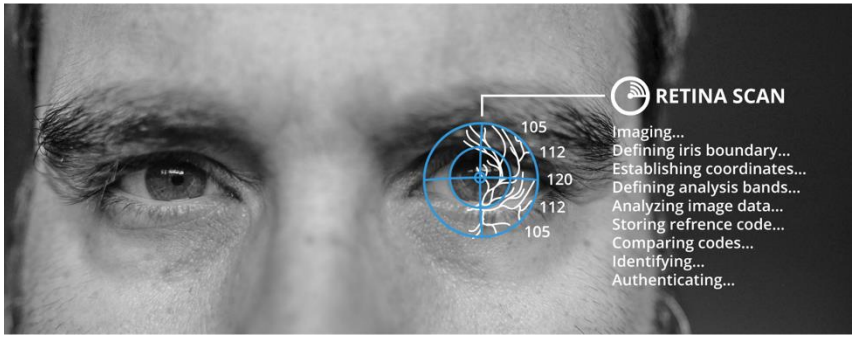


Photo by Ghost Presenter on Unsplash.

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Behavioral Technologies

- Something you do
  - Voice recognition
  - Gait analysis
  - Signature recognition
  - Typing
- Other uses than authentication
  - Identification/alerting
  - Continuous authentication/account locking

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Lesson 8

Implementing Identity and Account Management Controls

CompTIA®

Identity Management Controls

- Certificates and smart cards
  - Public key cryptography
  - Subject identified by a public key, wrapped in digital certificate
  - Private key must be kept secure
- Tokens
  - Authorizations issued under single sign-on
  - Avoids need for user to authenticate to each service
- Identity provider
  - Provisions and manages accounts
  - Processes authentication
  - Federated identity management

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Background Check and Onboarding Policies

- Human resources (HR) and personnel policies
  - Recruitment (hiring)
  - Operation (working)
  - Termination/separation (firing or retiring)
- Background check
- Onboarding
  - Welcoming a new employees or contractors to the organization
  - Account provisioning
  - Issuing credentials
  - Asset allocation
  - Training/policies
- Non-disclosure Agreement (NDA)

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Personnel Policies for Privilege Management

- Mitigate insider threat
- Separation of duties
  - Standard operating procedures (SOPs)
  - Shared authority
- Least privilege
  - Assign sufficient permissions only
  - Reduce risk from compromised accounts
- Job rotation
  - Distributes institutional knowledge and expertise
  - Reduces critical dependencies
- Mandatory vacations

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Offboarding Policies

- Identity and access management checks
  - Disable the user account and privileges
  - Ensure integrity and availability of information assets managed by the employee
- Retrieving company assets
- Returning personal assets
- Consider shared/generic accounts, security procedures that must be changed

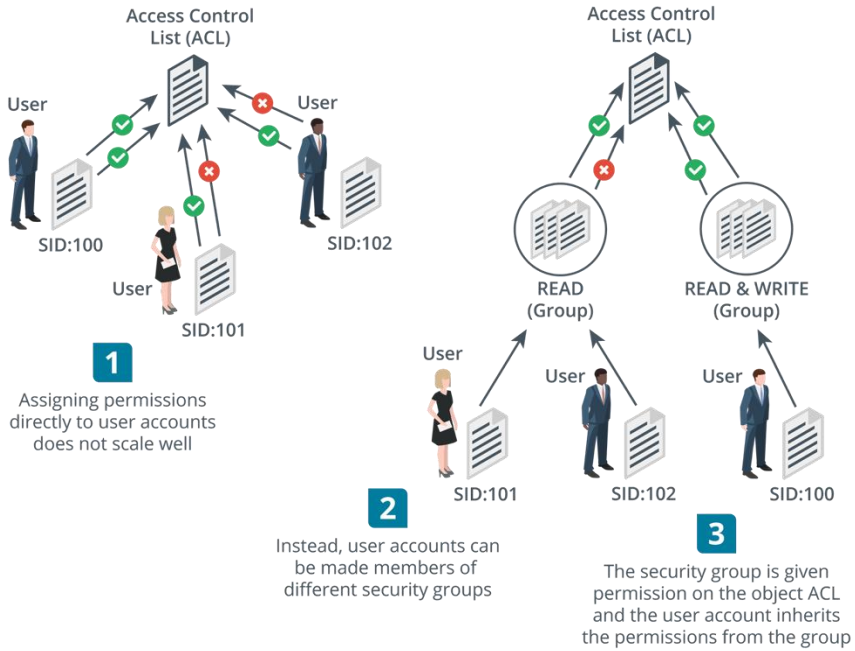
Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Security Account Types and Credential Management

- Standard users
  - Limited privileges
  - Should not be able to change the system configuration
  - Restricted to account profile
- Credential management policies for personnel
  - Password policy
  - Protect access to the account and prevent compromise
  - Educate risks from reusing credentials and social engineering
- Guest accounts
  - Account with no credentials (anonymous logon)
  - Unauthenticated access to hosts and websites
  - Must have very limited privileges or be disabled

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Security Group-Based Privileges



Images © 123RF.com.

- User-assigned privileges
  - Assign privileges directly to user accounts
  - Unmanageable if number of users is large
- Group-based privileges
  - Assign permissions to security groups and assign user accounts to relevant groups
  - Issues with users inheriting multiple permissions

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

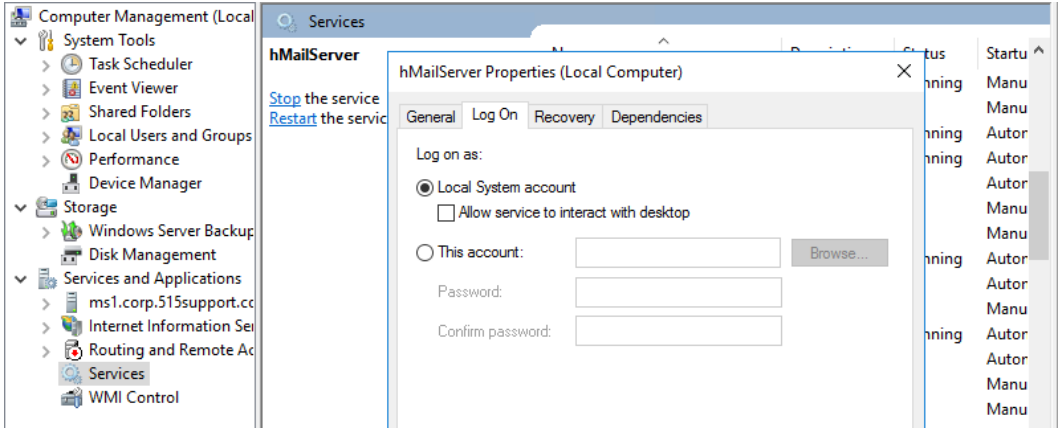
Administrator/Root Accounts

- Privileged/administrative accounts
  - Can change system configuration
- Generic administrator/root/superuser
  - User account with full control over system
  - Key target for attackers
  - Often disabled or usage restricted after install
- Administrator credential policies
  - Create specific accounts with least privileges (generic account prohibition)
  - Enforce multifactor authentication
- Default security groups
  - Administrators/sudoers

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Service Accounts

- Windows service accounts
  - System
  - Local Service
  - Network Service
- Linux accounts to run services (daemons)
  - Deny shell access
- Managing shared service account credentials



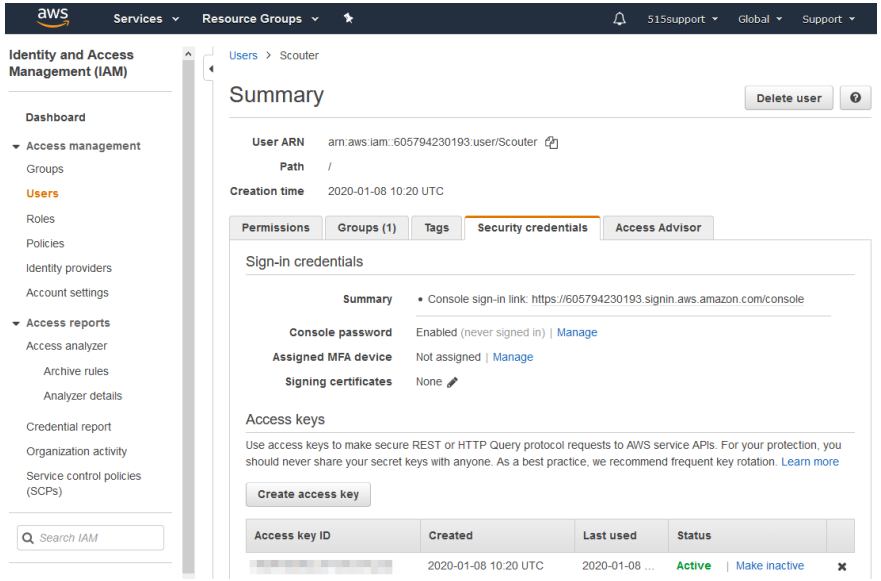
Screenshot used with permission from Microsoft.

Shared/Generic/Device Accounts and Credentials

- Shared accounts
  - Accounts whose credentials are known to more than one person
- Generic accounts
  - Accounts created by default on OS install
  - Only account available to manage a device
  - Might use a default password
- Risks from shared and generic accounts
  - Breaks principle of non-repudiation
  - Difficult to keep credential secure
- Credential policies for devices
- Privilege access management software

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Secure Shell Keys and Third-party Credentials



Screenshot used with permission from Amazon.com.

- Secure Shell (SSH) used for remote access
  - Host key identifies the server
  - User key pair used to authenticate to server
  - Server holds copy of valid users' public keys
  - Keys must be actively managed
- Third-party credentials
  - Passwords and keys to manage cloud services
  - Highly vulnerable to accidental disclosure

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

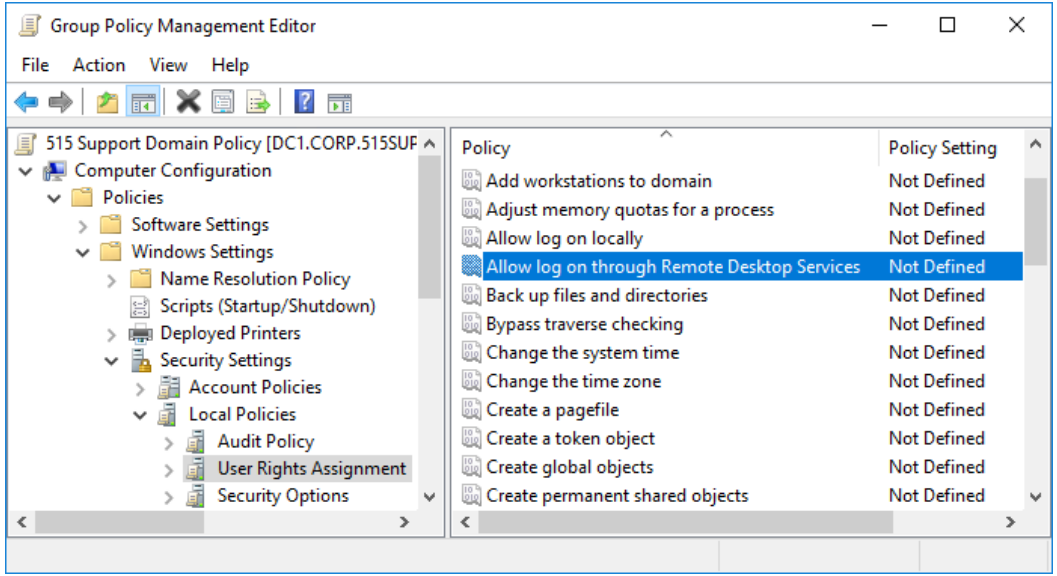
Topic 8B

Implement Account Policies

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Account Attributes and Access Policies

- Account attributes
  - Security ID, account name, credential
  - Extended profile attributes
  - Per-app settings and files
- Access policies
  - File permissions
  - Access rights
  - Active Directory Group Policy Objects (GPOs)



Screenshot used with permission from Microsoft.

Account Password Policy Settings

- Length
- Complexity
  - Character combinations
- Aging
- History and reuse
- NIST guidance
- Password hints

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

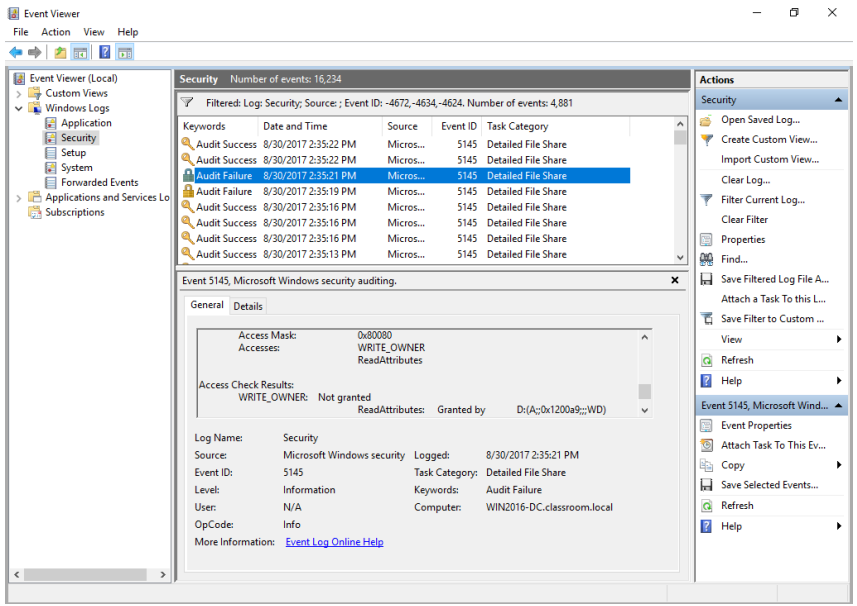
Account Restrictions

- Network location
  - Connecting from a VLAN or IP subnet/remote IP
  - Connecting to a machine type or group (clients versus servers)
  - Interactive versus remote logon
- Geolocation
  - By IP address
  - By Location Services
  - Geofencing
  - Geotagging
- Time-based restrictions
  - Logon hours
  - Logon duration
  - Impossible travel time/risky login

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

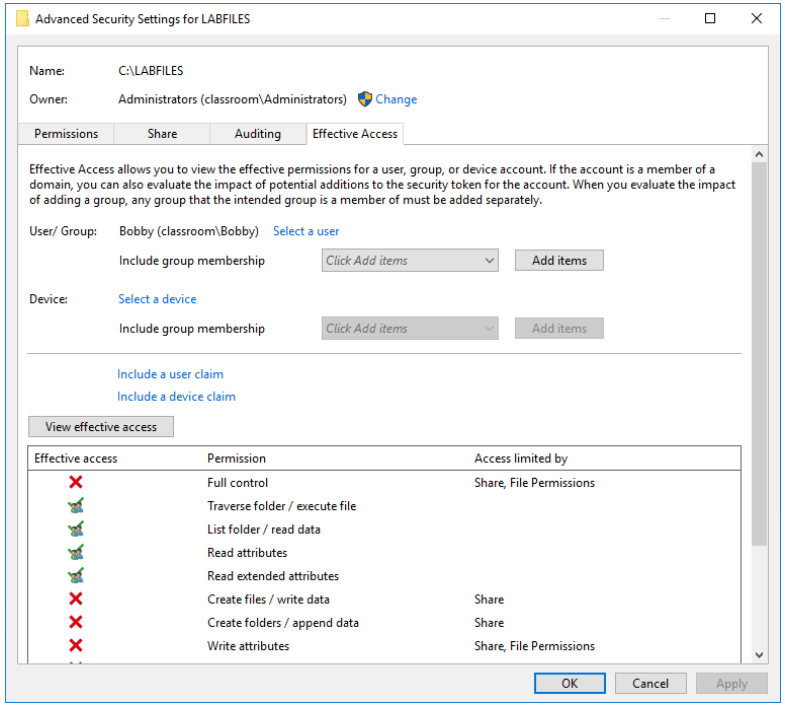
Account Audits

- Accounting and auditing to detect account misuse
  - Use of file permissions to read and modify data
  - Failed login or resource access attempts
- Recertification
  - Monitoring use of privileges
  - Granting/revoking privileges
  - Communication between IT and HR



Screenshot used with permission from Microsoft.

Account Permissions



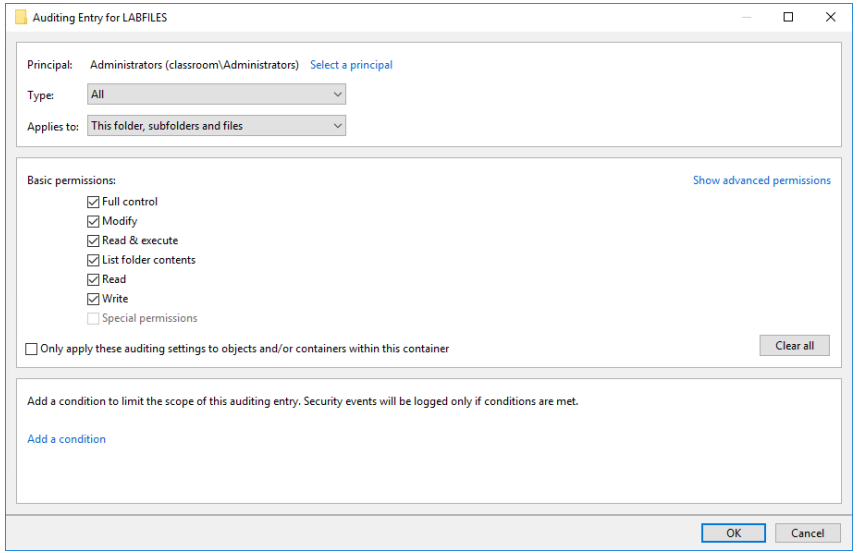
Screenshot used with permission from Microsoft.

- Impact of improperly configured accounts
  - Insufficient permissions
  - Unnecessary permissions
- Escalating and revoking privileges
- Permission auditing tools

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Usage Audits

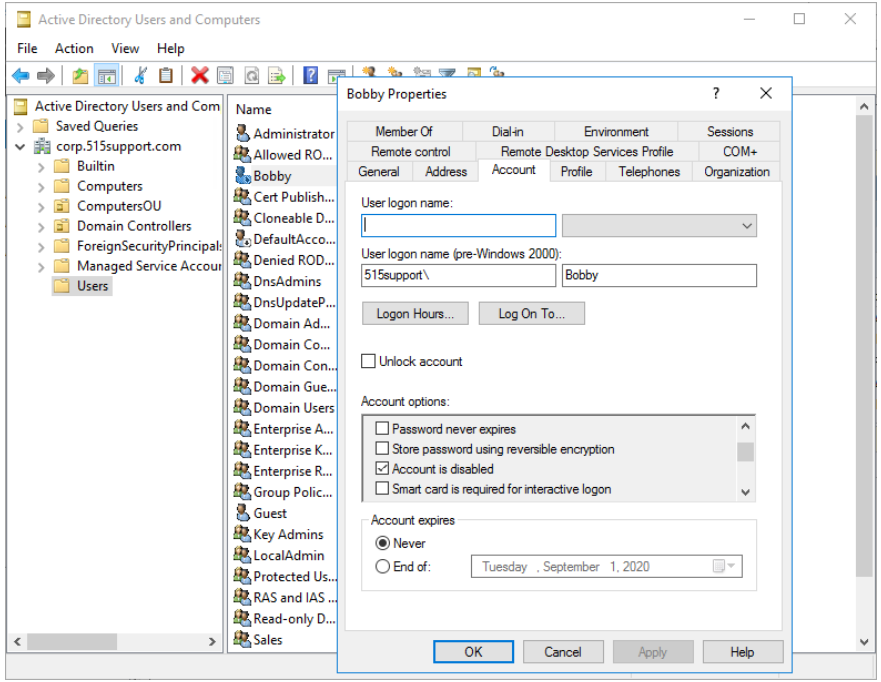
- Account logon and management events
- Process creation
- Object access (file system / file shares)
- Changes to audit policy
- Changes to system security and integrity (anti-virus, host firewall, and so on)



Screenshot used with permission from Microsoft.

Account Lockout and Disablement

Screenshot used with permission from Microsoft.



- Disablement
  - Login is disabled until manually re-enabled
  - Combine with remote logoff
- Lockout
  - Login is prevented for a period and then re-enabled
  - Policies to enforce automatic lockout

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Topic 8C

Implement Authorization Solutions

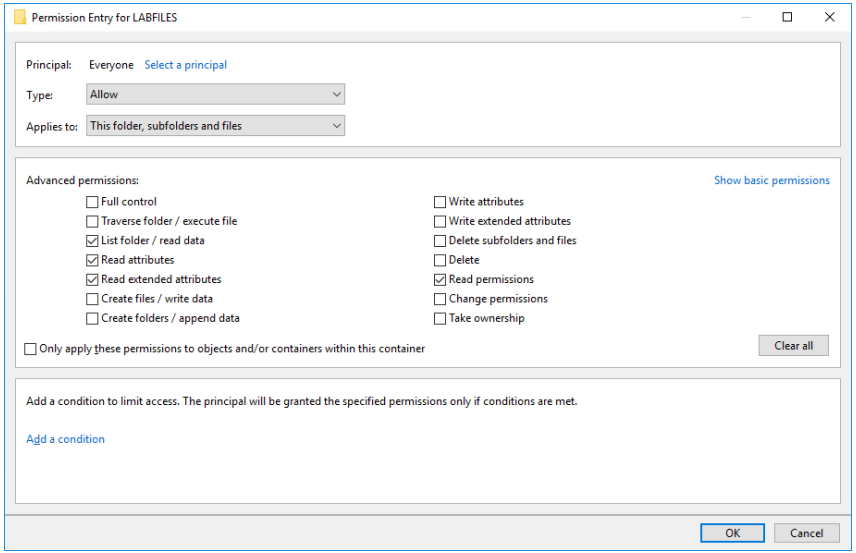
Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Discretionary and Role-Based Access Control

- Access control model determines how users receive permissions/rights
- Discretionary Access Control (DAC)
  - Based on resource ownership
  - Access Control Lists (ACLs)
  - Vulnerable to compromised privileged user accounts
- Role-Based Access Control (RBAC)
  - Non-discretionary and more centralized control
  - Based on defining roles then allocating users to roles
  - Users should only inherit role permissions to perform particular tasks

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

File System Security



Screenshot used with permission from Microsoft.

- Access Control List (ACL)
- Access Control Entry (ACE)
- File system support
- Linux permissions and chmod
  - Symbolic (rwx)
  - User, group, world
  - Octal
    - r=4
    - w=2
    - x=1

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Mandatory and Attribute-Based Access Control

- Mandatory Access Control (MAC)
  - Labels and clearance
  - System policies to restrict access
- Attribute-Based Access Control (ABAC)
  - Access decisions based on a combination of subject and object attributes plus any context-sensitive or system-wide attributes
  - Conditional access

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Rule-Based Access Control

- Non-discretionary
  - System determines rules, not users
- Conditional access
  - Continual authentication
  - User account control (UAC)
- Privileged access management
  - Policies, procedures, and technical controls to prevent the malicious abuse of privileged accounts

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Directory Services

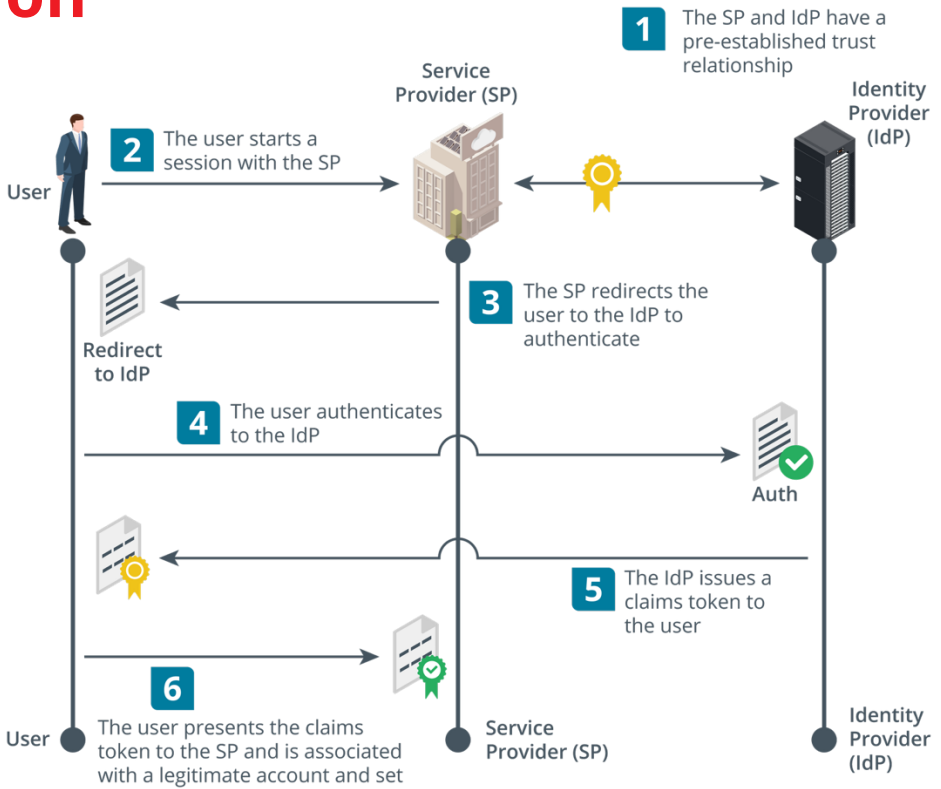
- Database of subjects
  - Users, computers, security groups/roles, and services
- Access Control Lists (authorizations)
- X.500 and Lightweight Directory Access Protocol (LDAP)
  - Distinguished names
  - Attribute=Value pairs

```
CN=WIDGETWEB, OU=Marketing, O=Widget, C=UK, DC=widget, DC=foo
```

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Federation and Attestation

- Federated identity management
  - Networks under separate administrative control share users
- Identity providers and attestation
- Cloud versus on-premises requirements



Images © 123rf.com.

Security Assertions Markup Language

- Open standard for implementing identity and service provider communications
- Attestations/assertions
  - XML format
  - Signed using XML signature specification
- Communications protocols
  - HTTPS
  - Simple Object Access Protocol (SOAP)

```
<samlp:Response xmlns:samlp="urn:oasis:names:tc:SAML:2.0:protocol"
xmlns:saml="urn:oasis:names:tc:SAML:2.0:assertion" ID="200"
Version="2.0"
IssueInstant="2020-01-01T20:00:10Z "
Destination="https://sp.foo/saml/acs" InResponseTo="100".
 <saml:Issuer>https://idp.foo/sso</saml:Issuer>
 <ds:Signature>...</ds:Signature>
 <samlp:Status>...(success)...</samlp:Status.
<saml:Assertion xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance"
xmlns:xs="http://www.w3.org/2001/XMLSchema" ID="2000" Version="2.0"
IssueInstant="2020-01-01T20:00:09Z">
<saml:Issuer>https://idp.foo/sso</saml:Issuer>
<ds:Signature>...</ds:Signature>
  <saml:Subject>...
  <saml:Conditions>...
   <saml:AudienceRestriction>...
   <saml:AuthnStatement>...
   <saml:AttributeStatement>
      <saml:Attribute>...
      <saml:Attribute>...
   </saml:AttributeStatement>
  </saml:Assertion>
</samlp:Response>
```

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

OAuth and OpenID Connect

- "User-centric" federated services better suited to consumer websites
  - Representational State Transfer (REST) Application Programming Interfaces (APIs) (RESTful APIs)
  - Framework for implementation not a protocol
- OAuth
  - Designed to communicate authorizations rather than explicitly authenticate a subject
  - Client sites and apps interact with OAuth IdPs and resource servers that hold the principal's account/data
  - Different flow types for server to server or mobile app to server
  - JavaScript object notation (JSON) web token (JWT)
- OpenID Connect (OIDC)
  - Adds functions and flows to OAuth to support explicit authentication

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Topic 8D

Explain the Importance of Personnel Policies

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Conduct Policies

- Acceptable use policy (AUP)
  - Employee use of employer's hardware and software assets
- Rules of behavior and social media analysis
  - General requirements for professional standards
  - Covers personal communications and social media accounts
  - Additional clauses for privileged users
- Use of personally owned devices
  - Bring your own device
  - Shadow IT
- Clean desk

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

User and Role-based Training

- Impacts and risks from untrained users
- Topics for security awareness
  - Overview of security policies
  - Incident response procedures
  - Site security procedures
  - Data handling
  - Password and account management
  - Awareness of social engineering and malware threats
  - Secure use of software such as browsers and email clients
- Role-based training
  - Appropriate language
  - Level of technical content

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Diversity of Training Techniques

- Engagement and retention
- Training delivery methods
- Phishing campaigns
  - Simulating phishing messages to test employee awareness
- Capture the flag
- Computer-based training (CBT)
  - Simulations
  - Branching scenarios
  - Gamification elements

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Lesson 8

Summary